POLYNEXUS HOSPITAL MANAGEMENT SYSTEM

Compliance Evidence Pack

NABH, DPDP, IT Act, CERT-In and EHR standards: what the software does, and the proof

12 October 2026 · For the NABH consultant and data-protection counsel

THE JOURNEY AT A GLANCE

Part	What it covers
1. About this pack	Who it is for and what it does not claim
2. NABH Digital Health Standards	Coverage, how it is proved, what is open
3. DPDP Act 2023 and Rules 2025	Each obligation, the feature, the evidence
4. IT Act 2000 and SPDI Rules 2011	Reasonable security practices
5. CERT-In Directions 2022	Incident reporting, logs, time sync
6. MoHFW EHR Standards 2016 and ABDM	Coding standards, interoperability
7. Other rules to review	Telemedicine, records retention, PCPNDT, pharmacy registers
8. Known gaps	What is not done, stated plainly
9. Questions for the reviewers	What we need you to confirm
10. How to see each control	A short demonstration script

Before you start

1 About this pack

For: the NABH consultant and the data-protection lawyer reviewing Polynexus HMS before we describe it to customers as compliant.

What it is: an engineering account of what the software does today, where each control is implemented, and the automated test that demonstrates it. It is evidence for your review, not a certification or a legal opinion.

Two things to keep in mind:

- **Accreditation and legal duties belong to the hospital.** NABH accredits hospitals, and the DPDP Act makes the hospital the data fiduciary. The software provides controls; policies, training, contracts and incident handling are the hospital's.
- **Two deployment modes.** The same software runs on our servers for many hospitals (SaaS) or on a hospital's own server (on-premise). Where a duty falls differently in each mode, this pack says so.

Annexes (in the code repository):

Annex	File
A. NABH compliance matrix, element by element	`Backend/docs/nabh/COMPLIANCE_MATRIX.md`
B. Engineering compliance review	`Backend/docs/COMPLIANCE_REVIEW.md`
C. ABDM sandbox readiness	`Backend/docs/compliance/ABDM_SANDBOX_READINESS.md`
D. Operations runbook (backups, logs, upgrades)	`Backend/deploy/RUNBOOK.md`
E. Latest automated test run	12 Oct 2026: 921 backend tests pass (3 known failures in unrelated hospital-switching and telephony tests), 63 frontend tests pass

2 NABH Digital Health Standards (HIS/EMR v1.2.1)

Coverage: 211 of 223 objective elements are implemented. 5 are partial (each needs an outside step such as ABDM or NHCX onboarding), 4 are organisational (vendor processes and ISO certifications), 2 are deferred by product decision (online payment gateway), and 1 is a gap (advanced ABDM FHIR profiles).

How it is proved: the matrix is generated from the code. Each element links to the code that implements it and, separately, to the automated tests that name it. **Every Core element has a test that demonstrates it.** In total 56 elements have a tagged test; the others are implemented and listed at the end of the matrix for tagging.

Status	Elements
Partial	COP.1.p (past records through ABHA), DAC.1.c (cross-browser run to record), FPM.4.i and IMS.1.d (NHCX), IMS.1.b (extended FHIR profiles)
Organisational	DOM.1.f (source-code management), DOM.2.b (support SLAs), IMS.3.a (ISO 27001:2022), IMS.3.b (ISO 82304-1)
Deferred	FPM.2.b, FPM.3.e (online payments; UPI, card and bank transfer are recorded manually)
Gap	IMS.1.c (advanced ABDM FHIR profiles)

3 DPDP Act 2023 and DPDP Rules 2025

Obligation	What the software does	Evidence
Notice (s.5)	Versioned notices per purpose (treatment, billing and insurance, reminders, marketing, research, ABDM sharing, telemedicine) in English, Hindi and Marathi. Published wording can't be edited; a change is a new version	Security & Governance → Consent notices; `privacy.ConsentNotice` ; `apps/privacy/test_consent_register.py`
Consent per purpose, and withdrawal as easy as giving it (s.6)	Consent recorded against the exact notice version, with method (signed, digital, verbal, portal) and who captured it; one-step withdrawal; patients who agreed to an older version are flagged to be asked again. Withdrawing marketing or reminders consent stops those messages	Patient → Consents; `privacy.PatientConsent` ; same test file
Reasonable security safeguards (s.8(5))	Encryption at rest of identifiers and contact details, including name, date of birth and email; role-based access; 2FA (several authenticator apps per person); password, lockout and screen-lock policy; field-level audit trail on clinical and patient records; access-denied logging	`apps/patients/test_encrypted_identity.py` , `apps/core/test_clinical_audit.py` , `apps/accounts/test_authenticators.py` , `apps/governance/tests.py`
Breach intimation (s.8(6), Rules)	Incident register: any staff member reports; deadlines from detection; Data Protection Board intimation and detailed report, and notifying affected people, each recorded; overdue steps raise critical alerts; an incident can't close until every report and the root cause are recorded	Security & Governance → Incidents & breaches; `apps/governance/test_incidents_and_logs.py`
Erasure when the purpose is served (s.8(7))	Erasure requests are handled through the data-rights workflow; soft delete with purge after a grace period	`privacy.DataRightsRequest` ; automation purge tests. **Open:** no per-category retention schedule (Part 8)
Children's data (s.9)	Consent can be recorded as given by a parent or guardian, by name	Consent register. **Open:** no verifiable parental-consent mechanism (Part 8)
Rights of access, correction, erasure (s.11–12)	Requests are logged, identity is verified before export or erasure, and completion is recorded	`privacy.DataRightsRequest` ; `apps/privacy/tests.py`
Grievance redressal (s.13)	Grievance tickets with an SLA	`privacy.GrievanceTicket`
Nomination (s.14)	Nominees per patient	`privacy.Nominee`
Data stays in the deployment	On-premise, nothing leaves the server unless an integration (WhatsApp, IVR, ABDM) is licensed and configured; AI runs on a local model	Licence feature gating; Part 1 of the compliance review

4 IT Act 2000 (s.43A) and SPDI Rules 2011

Health information is sensitive personal data under the SPDI Rules. Rule 8 expects reasonable security practices, with ISO 27001 as one recognised standard.

Practice	Software	Hospital / company
Encryption	AES-256-GCM field encryption with keys from the environment; production refuses development keys; key rotation supported	Protect the server's `.env` (the keys) and its backups
Access control	Role-based permissions, per-hospital isolation, 2FA, IP restrictions, instant session end on blocking	Assign roles carefully; review access periodically
Audit	Immutable audit log at the database level, field-level changes, security events	Review logs; keep them as required
Certification	—	ISO 27001:2022 certification of the vendor and hosting is organisational (NABH IMS.3.a)

5 CERT-In Directions (28 April 2022)

Direction	Software	Hospital / company
Report cyber incidents within 6 hours of noticing	Incident register with the 6-hour deadline, overdue alerts and the CERT-In reference recorded	Report to CERT-In; name a point of contact
Keep ICT system logs for 180 days	Daily application log files kept 180 days and purged after; audit-log retention can't be set below 180 days; security events and the audit log are kept in the database	Keep the `logs` folder on storage that is backed up; keep logs within India
Synchronise clocks with NTP servers of NIC or NPL	Containers use the server's clock	Point the server's time sync at NIC or NPL NTP servers (RUNBOOK)

6 MoHFW EHR Standards 2016 and ABDM

Standard	Software
Diagnoses: ICD-10	MRD coding with ICD-10 (NABH IMS.1.e)
Lab: LOINC	Lab tests carry LOINC codes (IMS.1.f)
Imaging: DICOM	DICOM header reading and viewer (IMS.1.g)
Drugs: SNOMED CT / NRCeS drug registry	Supported (IMS.1.h); coverage of the drug master to be checked
Exchange: HL7 FHIR R4 (ABDM profiles)	Prescription, lab, imaging, discharge and OP-consultation bundles, validated and carrying the ABHA
Audit trail and access control	Part 3 and Part 4
ABDM certification	Not yet done: see Annex C for status and plan

7 Other rules to review

We have not reviewed these against the software. They apply only where the hospital uses the matching module:

Rule	Module
Telemedicine Practice Guidelines 2020	Telemedicine (consent, identification, prescription limits)
PCPNDT Act: Form F and records	Radiology (ultrasound)
NDPS Act and Drugs and Cosmetics Rules: Schedule H1 and narcotics registers	Pharmacy
Clinical Establishments Act and state rules; NMC record-keeping	Medical records retention
Biomedical Waste Management Rules	Support services

8 Known gaps

Gap	Area	Plan
No per-category retention schedule for patient records, and no written rule for an erasure request that conflicts with a legal duty to keep records	DPDP s.8(7); medical-records law	Needs your retention periods (Part 9), then a configurable schedule
No verifiable parental-consent mechanism for children	DPDP s.9, Rules	Needs your view on what "verifiable" requires for a hospital
ABDM not certified; HIP data sharing not built	ABDM; NABH COP.1.p, IMS.1.b–d	Annex C
Advanced FHIR profiles	NABH IMS.1.c	Annex C, item 7
Online payment gateway	NABH FPM.2.b, FPM.3.e	Deferred by product decision
Other patient-like records (enquiries/leads, blood donors, referrals) still hold names unencrypted	DPDP s.8(5)	Same treatment as patients, next
Audit entries made before 12 Oct 2026 may include a record's display name, which for some records contained a diagnosis	DPDP s.8(5)	Fixed going forward; the audit table is immutable by design, so old entries are kept
ISO 27001 and ISO 82304-1 certification	NABH IMS.3	Organisational
Hospitals in SaaS share one database, separated in the application	Good practice	Database-level row security as a second layer, under consideration

9 Questions for the reviewers

For the data-protection lawyer:

1. Breach deadlines: we use DPB intimation "without delay" (alert after 24 hours), and the detailed report and notice to affected people within 72 hours of becoming aware. Is that the right reading of the Rules for a hospital?
2. Retention: how long must each category be kept (OPD records, IPD records, medico-legal cases, imaging, prescriptions, billing), and does that differ by state?
3. When a patient asks for erasure and the law requires the hospital to keep the record, what should the response say, and what may be erased?
4. What makes parental consent "verifiable" for children's records at a hospital front desk?
5. Is our notice structure (one per purpose, versioned, in three languages) adequate, and which purposes may rely on legitimate use rather than consent (for example treatment in an emergency)?
6. In SaaS mode, what must the hospital–Polynexus agreement say about our role as data processor, sub-processors and data location?

For the NABH consultant:

1. Is a test that names the element an acceptable form of evidence, or do assessors expect a recorded demonstration as well?
2. For the 4 organisational elements, what documents does the assessor expect from the vendor?
3. Do the partial elements (ABDM, NHCX) block accreditation at the level the hospital is applying for?

10 How to see each control

A test hospital with one administrator account is enough.

1. **Consent:** Security & Governance → Consent notices → publish a "Marketing" notice. Open a patient → Consents → Record → Patient agrees. Withdraw it, then check the patient's messaging opt-outs.
2. **Encryption:** register a patient, then show the database row holds unreadable values for name, date of birth, email and mobile, while searching "first three letters of the name" still finds them.
3. **Audit trail:** edit a nursing note and a prescription; Security & Governance → Audit trail shows who changed what (values hidden for encrypted fields).
4. **Incident:** Settings → Report incident. Security & Governance → Incidents shows the deadlines; record the CERT-In report and the Board steps; try to close it before the root cause is recorded.
5. **Access:** sign in as a receptionist: clinical menus are absent and clinical addresses are refused. Block a user: their open session ends at once.
6. **Logs:** on an on-premise server, the `logs` folder holds one file per service per day.